RATを介した攻撃者操作の録画収集とVLM・LLMによる自動分析可能性の検証

藤井 翔太[1,a)]　亀谷 功[1]　青木 翔[1]　久井 雅史[1]　川口 信隆[1]　佐藤 隆行[1]

概要：Remote Access Trojan（RAT）を介した攻撃では，攻撃者が感染端末へ遠隔接続し，情報の閲覧，ファイル操作，および認証情報の取得等を対話的に実施する．このような侵入後活動を把握するには，各種ログに加えて，攻撃者が画面上で何を閲覧し，どのような順序で操作したかを記録することが有用である．特に画面録画は，ログに残りにくい閲覧内容や操作過程を補完するとともに，攻撃者の挙動を把握することで，検知方法や防御対策を検討するための基礎情報となり得る．そこで本研究では，攻撃観測環境上で RAT を継続的に稼働させ，RAT を介して端末へ接続した攻撃者による一連の操作を画面録画として観測・収集した．具体的には，2025 年 5 月から 2026 年 1 月までに実行した 70 ケースの RAT のうち，画面上で操作を確認できた 8 件の侵入セッションを抽出し，23 件の画面上の活動を整理した．さらに，収集した操作録画の分析を支援するため，画面変化に基づくキーフレーム抽出，視覚言語モデル（VLM）による画面状態記述，大規模言語モデル（LLM）によるタイムライン生成と概要生成からなる分析システムを試作した．生成されたタイムラインを人手ラベルと比較した結果，完全対応は 18 件，部分対応は 3 件，非対応は 2 件であり，完全対応と部分対応を含むカバレッジは 91.30%（21/23）と，人手での整理結果と概ね対応するタイムラインや概要を生成できることを確認した．以上より，RAT を介した攻撃者操作を録画として収集することで侵入後の行動把握や検知・対策の検討に資する情報を獲得可能なことを示すとともに，VLM と LLM による侵入動画の自動分析が攻撃活動の把握を支援し得ることを予備的に示した．

キーワード：RAT，攻撃者行動分析，動画分析，視覚言語モデル

Recording Attacker Activities Conducted via RATs and Evaluating the Feasibility of Automated Video Analysis Using VLMs and LLMs

Shota Fujii[1,a)]　Isao Kametani[1]　Sho Aoki[1]　Masashi Hisai[1]　Nobutaka Kawaguchi[1]
Takayuki Sato[1]

Abstract: Remote Access Trojans (RATs) enable attackers to remotely access compromised hosts and interactively browse information, manipulate files, and obtain credentials. Understanding such post-compromise activities requires not only network and host logs but also records of what attackers viewed and how their actions unfolded over time. Screen recordings can complement conventional logs by preserving otherwise difficult-to-observe content and interaction sequences, providing useful information for detection and defensive analysis. In this study, we continuously operated RATs in a cyberattack observation environment and collected screen recordings of attacker operations conducted through them. Among 70 RAT execution cases from May 2025 to January 2026, we identified eight intrusion sessions with observable on-screen operations and organized 23 activities. To support analysis of these recordings, we implemented a system that extracts keyframes based on screen changes, describes screen states using a VLM, and generates timelines and overviews using an LLM. Compared with manually annotated activities, the generated timelines showed 18 complete, three partial, and two non-matches, yielding a coverage rate of 91.30% (21/23). These results demonstrate the value of recording RAT-mediated attacker operations for understanding post-compromise behavior and informing detection and defense, and preliminarily show that VLM- and LLM-based automated video analysis can support the understanding of attacker activities.

Keywords: RAT, Attacker Behavior Analysis, Video-based Malware Analysis, Vision-Language Models

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

1. はじめに

Remote Access Trojan（RAT）を用いた攻撃では，感染端末を攻撃者が遠隔から監視・操作し，画面上に表示された情報を確認しながら，次に実行する操作を逐次判断する．このような対話的な侵入後活動では，ファイルや認証情報の探索，メールやチャットの閲覧，セキュリティ製品の状態確認等が，人手による一連の GUI 操作として現れる．プロセス，ファイル，レジストリ，ネットワーク通信等を対象とする従来の動的解析は，マルウェアの実行時挙動を把握するうえで重要である [1]．一方で，RAT を介した対話的な攻撃では，攻撃者がブラウザやアプリケーションを操作し，画面上の情報を閲覧しながら行動するため，こうした GUI 操作を直接観測することで，閲覧対象，操作内容，および攻撃者が関心を示した情報等を把握できる [2]．

一方，RAT 操作者による一連の GUI 操作を含む観測データ，とりわけ画面録画を伴うデータの報告例は，一般的なマルウェア動的解析で得られるログと比較して限定的である．その背景には，RAT を実行しても直ちに人手による遠隔操作が行われるとは限らず，操作者がいつ接続し，どの程度の時間，どのような操作を行うかを事前に予測できないため，長期間にわたって検体を稼働させ，継続的に観測する必要があることが挙げられる．また，実マルウェアを動作させながら研究環境外への影響を抑制できる安全な観測環境も必要となるため，通常の自動動的解析と比べて観測データの収集には高いコストを要する．しかし，前述の通り，画面録画からは通信・ホストログだけでは把握しにくい閲覧対象や一連の GUI 操作を直接確認できることから，RAT による侵入後活動を理解する上で，動画を含む観測データを蓄積することには重要な意義がある．

加えて，収集した動画を分析する際の人的コストも課題となる．例えば，Bilodeau らは，RDP を介した攻撃者の遠隔操作を長期間観測し，100 時間に及ぶ録画を分析することで攻撃者の行動を整理している [3]．本研究のように攻撃者による操作入力が生じた区間のみを録画する場合であっても，動画中には文字入力の途中やマウス操作に伴う類似した画面が多数含まれるほか，ブラウザ，メール，ファイル管理ソフトウェア等の複数のアプリケーションをまたいで操作が行われる．このため，分析者が動画を逐次確認し，どの時点で何が表示され，どのような操作が行われたかを抽出して時系列に整理する作業には依然として相応の労力を要する．動画を含む RAT 観測データを継続的に蓄積・活用するためには，このような確認・整理作業を支援する手段も必要となる．

そこで本研究では，RAT を介した実際の攻撃者操作を動画を含む形で観測・収集する（Study 1）とともに，収集した動画の分析を支援する手法について予備的に検証する（Study 2）．Study 1 では，サイバー攻撃誘引基盤 STARDUST 上で RAT を継続的に動作させ，攻撃者による遠隔操作を画面録画として観測する．2025 年 5 月から 2026 年 1 月までに 70 ケースの RAT を実行し，そのうち画面上で攻撃者の操作を確認できた 8 件の侵入セッションについて，動画とともに 23 件の画面上の活動を整理する．これにより，RAT 操作者が侵入後に実際に閲覧・操作した画面情報を時系列に確認可能な観測データを収集する．

Study 2 では，収集した操作録画を分析者が確認・整理する作業の支援を試みる．近年，画像と言語を統合して扱う Vision-Language Model（VLM）による GUI 理解や，Large Language Model（LLM）を用いた操作系列の理解に関する研究が進展している [4–6]．そこで，これらの技術を RAT 操作録画の分析支援に応用し，画面変化に基づいて抽出したキーフレームを VLM によって自然言語で記述した後，LLM によって時系列に統合することで，攻撃者の操作を示すタイムラインと動画全体の俯瞰要約を生成する分析システムを試作する．さらに，生成されたタイムラインを人手による分析結果と比較し，収集した RAT 操作録画に対してどの程度分析を支援できるかを予備的に評価する．

本稿における主な貢献は以下の通りである．

- 解析観測上で RAT を観測し，8 件の RAT 侵入セッション・23 件の攻撃者活動から構成される観測データを，動画を含む形でデータとして収集・整理した．
- 攻撃者侵入動画をキーフレームへ圧縮し，OCR, VLM, および LLM を段階的に適用することによってタイムラインと俯瞰要約を生成する分析システムを試作した．
- 生成されたタイムラインと人手による分析結果を比較し，23 件中 21 件（91.30%）が一致または部分一致することを確認することでその分析可能性を予備的に示すとともに，攻撃者の意図推定や操作後の画面変化が残らない活動の認識が課題となることを明らかにした．

2. 背景と関連研究

2.1 RAT による遠隔操作型攻撃

RAT は，感染端末を攻撃者が遠隔から監視・操作するための機能を備えたマルウェアである．RAT に感染した端末では，攻撃者が画面を閲覧し，マウスやキーボードを操作するほか，ファイルの取得，プログラムの実行，Web カメラの制御，認証情報の取得等を行うことが可能となる．攻撃者は，侵入先の環境や画面に表示された情報を確認しながら次の操作を判断できるため，RAT による攻撃は，事前に規定された処理を自動実行するマルウェアとは異なる対話的な性質を有する．

また，RAT は実際のサイバー攻撃において広く悪用さ

[1] 株式会社 日立製作所，Hitachi, Ltd.
[a)] shota.fujii.xh@hitachi.com

© 2026 Information Processing Society of Japan

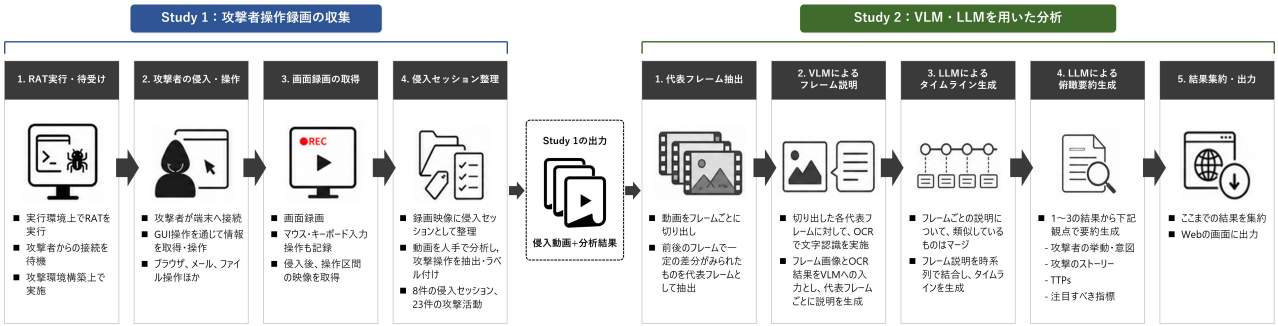


図 1　本研究の全体像：攻撃者操作録画の収集（Study 1）と VLM・LLM を用いた分析（Study 2）

れている．Huntress の 2025 Cyber Threat Report では，2024 年に同社が観測したリモートアクセス関連インシデントの 75%以上が RAT に起因するものであり，AsyncRAT 等の複数の RAT が継続的に観測されたと報告されている [7]．このため，RAT による侵害の検知・分析と，侵入後に行われる活動を把握するための技術を継続的に高度化することが重要であると言える．

2.2　動的解析と攻撃者行動の観測

マルウェアの動的解析は，隔離された解析環境で検体を実際に動作させ，プロセス，ファイル，レジストリ，ネットワーク通信等に生じる変化を観測する手法である [1]．実際に検体を動作させるため，静的解析では把握が困難な実行時の挙動を取得することが期待できる．

攻撃者自身の操作を観測する方法としては，ハニーポットや遠隔デスクトップ環境を利用した研究も行われている．例えば，RDP 通信を中継・記録する PyRDP では，攻撃者の遠隔操作を再生可能な形式で保存し，接続後に行われたファイル操作や画面操作を分析できる [3]．また，Farinholt らは，実環境に展開したハニーポットを用いて DarkComet RAT の操作者を観測し，攻撃者が端末内のファイルを手動で探索することや，追加の攻撃ツールを導入すること等を明らかにした [2]．RATScope は，Event Tracing for Windows によって収集した監査ログとプログラム挙動モデルを用いて，RAT によるファイル操作や通信等の意味的な挙動を再構成する [8]．また，AIRTAG は，システムログに含まれるテキストを教師なし学習によって解析し，攻撃に関連するエンティティを抽出することで，攻撃調査の自動化を試みている [9]．

このような観測手法は，攻撃者の操作・攻撃手順や関心を示した情報等を把握できる点で有用である．また，RAT の通信や内部機能を解析するだけでなく，RAT を介して攻撃者が実際に何を行うかを観測することの重要性を示している．特に，ブラウザ，メール，ファイル，認証情報，セキュリティ製品等に対する一連の操作を把握することは，侵入後の行動を理解し，検知・対応策を検討するうえで有用であると言える．

2.3　画面録画の分析

動的マルウェア解析における画面情報の利用について，我々は，92 のマルウェアファミリに関する 211 件の解析レポートに含まれる 3,590 枚の画面を人手で分類し，ログのみでは把握しにくい情報が画面から得られることを示している [10]．特に，RAT を介した遠隔操作では，攻撃者が利用したアプリケーション，画面上で閲覧した情報，操作の順序，操作中の停滞や試行錯誤等が画面遷移として記録される．このため，通信・ホストログを補完して操作の流れを把握する情報源となり得る．

また，近年では，LLM や VLM を GUI 画面の理解に利用する研究が進められている．例えば，ScreenAI は，スクリーンショットに含まれる情報を認識し，画面に関する質問応答や要約を行う VLM である [4]．また，ScreenLLM は，ソフトウェアの操作録画から画面変化を伴うキーフレームを抽出し，OCR 結果やカーソル位置等を含む画面表現を生成することで，GUI 上の利用者操作とその意図を理解・予測する [6]．

2.4　本研究の位置づけ

既存研究により，RAT を介した攻撃者の操作を解析環境上で観測できること，画面情報からログのみでは把握しにくい情報を取得できること，および VLM や LLM が GUI や動画の理解に活用可能であることが示されている．一方，上述のような観測事例は存在するものの，実際の RAT 操作者による一連の画面操作を録画として収集し，分析用データとして整理した報告は限定的である．さらに，録画を取得できた場合にも，分析者は複数のアプリケーションにまたがる画面状態や操作順序を確認して整理を行う必要があることから，その確認・整理を支援する手段が重要になると考えられる．一方で，一般的な動画理解に対する VLM・LLM の利用は進展しているものの，これらを RAT 操作録画に適用し，分析支援に利用できるかについては十分に検討されていない．

そこで，本研究では，Study 1 として，2025 年 5 月から 2026 年 1 月にかけて RAT を解析環境で継続的に動作させ，実際の RAT 操作者による 8 件の侵入セッションを画

© 2026 Information Processing Society of Japan

表 1　観測された画面上の活動の概要

ケース	実行日	MD5	ファミリ名	画面上で観測された攻撃者の挙動
Case 1	2025-05-09	995284d45df0fff802319e04b25fde3b	AsyncRAT	(1) ブラウザを起動，(2) インストーラを手動で削除.
Case 2	2025-05-09	c5d6229230f42660ced02646e16c9681	AsyncRAT	(1) ブラウザを起動してウォレットのパスワードを閲覧，(2) システムをシャットダウン.
Case 3	2025-05-30	567e3e7cb7ab1168e2bc87b50c7a3c26	AsyncRAT	(1) Chrome および Edge を用いて Gmail へ遠隔アクセス.
Case 4	2025-07-30	b455723271f36ab6a9367e7a85f71b0a	QuasarRAT	(1) アプリケーションを遠隔で検索.
Case 5	2025-09-18	02bbe6f55e5545cdee8d65ca62fe0492	NanoCore	(1) Outlook を起動してメールを閲覧，(2) Mail PassView でアカウント情報を抽出，(3) 抽出した情報をメモ帳へ保存.
Case 6	2025-10-09	ab71b3c40f5d33efec55ded45d755b33	VeletrixLoader	(1) アンチウイルスソフトウェアの状態を確認，(2) ファイルを検索して Excel ファイルを開く，(3) Bandicam の画面を開いた後，約 15 分後に録画を停止.
Case 7	2025-10-31	c9385224c6c2d84b6878c8c6e9289fc8	NanoCore	(1) Outlook を起動してメールを閲覧，(2) Outlook の予定表を改変，(3) 連絡先を閲覧.
Case 8	2026-01-24	021e011417542d19034ab1d04a11d9b4	ValleyRAT	(1) メールを閲覧，(2) Webex の起動を試行，(3) Zoom を起動して過去のチャット閲覧を試行，(4) Slack のチャット閲覧を試行，(5) Yarai の状態を確認，(6) Bandicam の状態を確認，(7) mipDlp.exe を確認，(8) Vision One を確認.
合計				8 ケース，23 件の活動

面録画として収集・整理する．さらに Study 2 として，収集した RAT 操作録画をタイムラインと概要へ整理する分析システムを試作し，人手で分析した攻撃者の活動が含まれる割合を活動カバレッジとして予備評価する．本研究では，これら 2 つの Study を通じて，RAT 侵入後活動の把握に向けた観測データの蓄積と分析支援の双方に関する基礎的知見の提供を図る．

3. Study 1：攻撃者操作録画の収集と整理

3.1 観測環境と録画方法

図 1 に本研究の全体像を示し，同図の左側に Study 1 の流れを示す．本研究における RAT を介した攻撃者操作の観測は，国立研究開発法人情報通信研究機構（NICT）が研究開発・運用するサイバー攻撃誘引基盤 STARDUST [11] 上で主に第 2 著者が実施した．STARDUST は，実在する組織の ICT 環境を模擬した「並行ネットワーク」を仮想化基盤上に構築し，その内部に攻撃者を誘引することで，マルウェア感染後に行われる人手による攻撃活動を観測・収集するための大規模解析基盤である．並行ネットワークには，クライアント端末に加えて認証サーバ，ファイルサーバ，Web サーバ等を配置でき，模擬データやログを含む実組織に近い ICT 環境を構成できる．また，攻撃者の探索や情報取得に係る活動を誘発するため，STARDUST のデフォルト環境をカスタマイズし，メール情報や疑似的な個人情報を含むファイル群をデスクトップ等に配置した．ただし，有効な認証情報や実在する個人情報等の機密データは含めていない．

本研究では，並行ネットワーク内の模擬端末上で観測対象の RAT 検体を実行し，C2 サーバを介して行われる遠隔操作を観測した．その際，各検体は数時間から最長 1 週間程度動作させ，攻撃者の侵入を待ち受けした．また，STARDUST では，模擬環境を管理系ネットワーク等から隔離した上で，ネットワーク通信およびホスト上の挙動を，攻撃者に観測を察知されにくい形で収集できる．これにより，実運用環境に影響を与えることなく，RAT 感染後に攻撃者が行う一連の操作を時系列に記録した．RAT サンプルは事前に準備したスナップショット上で実行し，各実験後には環境を初期状態へ復元した．

また，画面録画ソフト Bandicam[*1] によって RAT 実行中の画面を録画した．この際，Bandicam はバックグラウンドで実行することにより，できる限り攻撃者に気づかれにくくするように工夫を施した．なお，Bandicam のマウスやキーボードの操作を検知して録画する機能を用いることで，攻撃者が侵入・操作した区間のみを録画した．

3.2 観測された侵入セッション

前述の環境において，2025 年 5 月 9 日から 2026 年 1 月 24 日までの期間中に 70 ケースの RAT を実行し，解析環境で継続的に動作させ，攻撃者の侵入の誘発や侵入時の挙動記録を試みた．なお，動作させた検体は，メール等を介して自組織に着弾したもの，或いは OSINT 情報（SNS での情報や VirusTotal での検体ハンティング）によって取得したものである．本研究では，RAT の接続状態だけではなく，画面上で攻撃者の操作が確認できることをセッション条件とした．例えば，RAT が C2 へ接続していても，攻撃者の侵入や操作がなく，画面変化や入力が確認できない場合は侵入セッションに含めないこととした．この定義の下，結果として，8 件の攻撃者による遠隔操作を画面録画として観測することに成功した．この 8 件についての概要を**表 1** に示す．

表 1 の「画面上で観測された攻撃者の挙動」の列に，動画で記録できた攻撃者の挙動を示している．攻撃者が侵入時にまずブラウザを開いて外部への疎通確認を実施したり，ブラウザに記録された認証情報やウォレット情報の参照を試みている様子が記録された（Case 1，2）．また，メール情報を参照したり，その結果得られた情報をテキストファイルに書き出して攻撃者のもとへ持ち去ろうとしている様子も伺える（Case 3，5，7，8）．情報窃取の対象はメールに限らず，Zoom や Slack のチャットにも及んでいる（Case 8）．更に，アンチウイルスソフトの存在や稼働状態を確認する様子も見られた（Case 6，8）．加えて，解析環境であることや監視されていることに気づいたと思われる攻撃者が Bandicam の録画を停止したり（Case 6），Outlook の予

[*1] https://www.bandicam.com/

© 2026 Information Processing Society of Japan

定表に無意味な文字列「aaaa...」を書き込む場面も見られた（Case 7）.

こうしたデータは，従前の分析システムが具備・記録するシステムのログからは推量することが難しい画面上に現れる情報であり，攻撃者の挙動や傾向，ひいては検知ロジックや対策の検討に繋がり得る情報とも言えるため，収集・分析することに価値があるものと考えられる.

3.3 分析用データセット

先述の通り，本研究では，Study 2 において録画された攻撃者の行動の自動分析可能性を検証する．この検証に際してのデータセットとしては，表 1 の 8 ケースの侵入動画，23 個の攻撃活動を用いる．各侵入動画に対して，人手で確認してアノテーションした結果が表 1 の「観測された攻撃者の挙動」の列に記載された内容であるが，自動分析を行った際，この人手の分析結果に対するカバレッジを測ることによって，自動分析可能性を検証する.

4. Study 2：攻撃者操作録画の分析支援

4.1 全体像

図 1 右側に Study 2 に係る分析システムの処理フローを示す．分析システムは，攻撃者の操作を含む動画を入力とし，当該動画に含まれる攻撃者の操作を示すタイムラインと動画全体の俯瞰要約を生成することで分析の支援を図る.

本システムでは，まず前後のフレーム間に生じた画面変化を基に分析対象となるキーフレームを抽出する．次に，各キーフレームの画像および OCR によって取得した文字列を VLM へ入力し，その時点における画面の状態や攻撃者の操作を自然言語で記述する．さらに，生成されたフレーム単位の記述を LLM によって時系列に統合し，攻撃者の一連の操作を示すタイムラインと，動画全体を俯瞰する要約を生成する．以降の節では，本システムについて，コンポーネントごとに詳述する.

4.2 キーフレーム抽出

キーフレーム抽出では，入力された動画をフレームごとに切り出し，前後のフレーム間に一定以上の差分がみられたフレームを代表フレームとして抽出する．侵入動画の性質上，操作入力の前後や文字入力中には，内容の近いフレームが連続して記録される．すべてのフレームを後段の VLM へ入力すると，処理時間と計算資源の消費が増えるだけでなく，類似した記述が大量に生成される．そこで，本コンポーネントでは，画面表示に一定以上の変化が生じたフレームを抽出し，後段の分析対象を削減する.

ここで対象とする画面変化には，ウィンドウやダイアログの表示，アプリケーションの切替え，メニューの展開，コマンドの実行結果の表示等が含まれる．一方で，マウスポインタのわずかな移動等，攻撃者の操作内容を把握する上で重要性の低い変化については，可能な限り抽出対象から除外する．抽出した各キーフレームには，元動画における時刻情報を対応付け，後段で攻撃者の操作を時系列に再構成できるようにする．この画面変化をとらえるために，dHash（Difference Hash）を用いて前後のフレームでの画像間の差分を算出し，その差分が閾値以上だった場合に差分があるとして判定・抽出することとした.

4.3 VLM による画面状態記述

VLM による画面状態記述では，前段で抽出したキーフレームごとに，画面上で生じている状況や攻撃者の操作内容を自然言語で記述する．本コンポーネントでは，はじめに各キーフレームに対して OCR を実行し，ウィンドウタイトル，ファイル名，コマンド，メニュー項目，メッセージ等の画面上の文字列を抽出する．その後，キーフレームの画像と OCR による文字列の両方を VLM に入力し，フレーム単位の説明文を生成する.

画像と OCR 結果を併用することで，画面全体の視覚的な状況に加え，小さく表示された文字列やコマンドの内容を補完的に把握する．生成する説明には，使用されているアプリケーション，表示されているウィンドウ，選択または入力された項目，操作の結果として生じた画面変化等を含める．これにより，各キーフレームを個別に確認しなくても，その時点で攻撃者が行っていた操作をテキストとして参照できるようにする.

4.4 LLM によるタイムライン生成

LLM によるタイムライン生成では，フレーム単位で生成された説明文を時刻順に整理し，攻撃者の一連の操作を示すタイムラインを生成する．キーフレーム抽出後も，同一のウィンドウや操作過程を示す類似したフレームが連続して抽出される場合がある．このため，フレーム記述を単純に連結すると，同一または類似した内容が繰り返され，攻撃活動の流れを把握しにくくなる.

そこで，本コンポーネントでは，時間的に連続し，かつ内容が類似するフレーム記述を一つの操作区間として統合する．続いて，統合した操作区間を元動画の時刻順に並べ，攻撃者がいつ，どのようなアプリケーションを使用し，どのような操作を行ったかを示すタイムラインを生成する．これにより，フレーム単位の細かな記述を操作単位の記録へ変換する．この際の説明の生成に LLM を活用する.

4.5 LLM による俯瞰要約生成

LLM による俯瞰要約では，生成されたタイムラインおよびフレーム記述を基に，動画全体に記録された侵入・攻撃活動を複数の観点から要約する．タイムラインは個々の操作を時系列に確認する用途に適している一方で，長時間の侵入動画では操作項目が多くなり，攻撃活動の全体像を

© 2026 Information Processing Society of Japan

短時間で把握することが難しい．そこで，本コンポーネントでは，個別の操作記録を統合し，分析者が動画全体の概要を把握するための要約を生成する．

具体的には，攻撃者または攻撃活動の特徴，侵入後に行われた操作の経緯，観測された TTPs（Tactics, Techniques, and Procedures：TTP），および分析上注目すべき情報を整理する．これにより，分析者が詳細なタイムラインを確認する前に，攻撃者の目的や実施した可能性のある操作を概観できるようにする．

4.6 結果集約・出力

結果の集約と出力では，前段までに生成されたフレーム記述，タイムライン，および俯瞰要約を一つの分析結果として集約する．各コンポーネントの出力は分析粒度が異なり，フレーム記述は個々の画面変化の確認，タイムラインは操作順序の追跡，俯瞰要約は攻撃活動全体の把握に用いられる．本コンポーネントでは，これらを相互に参照可能な形で整理し，Web UI 上に出力する．

分析者は Web UI を通じて，動画全体の要約を確認した後，タイムラインに沿って個々の操作を追跡し，必要に応じてフレーム単位の記述を確認できる．このように，複数の粒度で生成された分析結果を集約して提示することで，長時間の侵入動画に対する確認作業の支援を図る．

4.7 ローカル LLM 実行基盤

VLM や LLM を用いる各コンポーネントは，Ollama を利用したローカル LLM 実行基盤上で動作する．侵入動画には，マルウェアの実行状況，攻撃者が入力したコマンド，アクセスしたファイルやサービス等，取扱いに注意を要する情報が含まれる可能性がある．このため，本システムでは，動画，キーフレーム，OCR 結果，および生成された分析結果を外部のクラウド型 AI サービスへ送信せず，ローカル環境内で処理する構成とした．

5. 予備評価

5.1 評価概要

4 章で述べた分析システムのプロトタイプ実装を行い，攻撃挙動録画の自動分析可能性について，予備評価を実施する．具体的には，分析システムに表 1 に示した 8 ケースの侵入動画を入力として与え，その結果出力されたタイムラインを同じく表 1 に示した 23 個の攻撃活動と比較し，そのカバレッジを測ることによって，人手の分析とどの程度一致するか，ひいては自動分析の可能性があるかを検証する．なお，人手の分析データ作成は第 1 著者と第 2 著者，一致度の判定は第 1 著者と第 4 著者のそれぞれ 2 名体制で実施することによって，客観性の確保を図った．

また，各ケースで生成された要約やタイムラインについて，本文では完全対応例として Case 2 と 5，非対応を含む例として Case 6 を示し，Case 7 と 8 の詳細と関連図は付録に示す．その後，生成される要約やタイムラインに係る傾向，LLM/VLM の得手不得手に関する考察を実施する．

なお，分析システムに係る実装やパラメータは次の通りである．dHash の差分とみなすための閾値はいくつかの画像を用いた予備評価を通して，今回は 8 と設定した．フレームの切り出しには `OpenCV 4.10.0`，OCR には `Tesseract OCR 5.3.4`，フレーム説明の VLM には `qwen3-vl:30b`，タイムラインと俯瞰要約生成の LLM には `gpt-oss:20b` を，`Ollama 0.30.0` にてそれぞれデフォルトパラメータの設定で利用した．フレーム説明，タイムライン，および俯瞰要約説明のためのプロンプトは，4 章で説明した内容をベースに各タスクの動機と内容を説明する形で作成した．それぞれの詳細は，付録 A.2 に示す．

5.2 活動カバレッジ評価結果

表 2 に評価結果を示す．完全対応は 18 件，部分対応は 3 件，非対応は 2 件であった．したがって，完全対応率は 18/23（78.26%），完全対応と部分対応を含む活動カバレッジは 21/23（91.30%）となった．

Case 2 では，ウォレットのパスワード閲覧とシステムのシャットダウンの 2 件がいずれも完全対応となった．生成結果には，Edge のパスワード管理画面へのアクセスとシャットダウンが時刻順に記述された．Case 7 では，メール閲覧と連絡先閲覧の 2 件が完全対応，予定表の改変が部分対応となった．生成結果は Outlook 上で長い文字列が入力されたことを記述したが，予定表項目の改変としての記述が十分に具体的ではなかったため部分対応とした．Case 8 では，8 件中 6 件が完全対応，Zoom での過去チャット閲覧が部分対応，Bandicam の状態確認が非対応となった．生成結果には Zoom の起動は記述されたが過去チャットの閲覧対象までは明示されず，Bandicam に対応する記述は確認できなかった．そのほか，Case 5 の 3 件はすべて完全対応となり，Case 6 ではアンチウイルスソフトウェアの状態確認と Excel ファイルの閲覧が完全対応，Bandicam の録画停止が非対応となった．部分対応は Case 1，7，8 の各 1 件，非対応は Case 6，8 の各 1 件だった．

5.3 ケーススタディ

5.3.1 Case 2（○ 2，△ 0，× 0；活動カバレッジ 2/2）

人手による分析結果：（1）ブラウザを起動してウォレットのパスワードを閲覧，（2）システムをシャットダウン．

図 2 に，本システムによって出力された Case 2 の概要とタイムラインを一部抜粋して示す．生成結果は，Edge のパスワード管理画面へのアクセスと，その後のシステムのシャットダウンに言及しており，2 件とも完全対応と判定した．動画から抽出された，ブラウザの設定ページからプロファイルページを経由してウォレットのパスワード管理

© 2026 Information Processing Society of Japan

表 2　人手ラベルに対する活動カバレッジ評価結果

ケース	観測された攻撃者の挙動	一致判定
Case 1	(1) ブラウザを起動	△
	(2) インストーラを手動で削除	○
Case 2	(1) ブラウザを起動してウォレットのパスワードを閲覧	○
	(2) システムをシャットダウン	○
Case 3	(1) Chrome および Edge を用いて Gmail へ遠隔アクセス	○
Case 4	(1) アプリケーションを遠隔で検索	○
	(1) Outlook を起動してメールを閲覧	○
	(2) Mail PassView でアカウント情報を抽出	○
	(3) 抽出した情報をメモ帳へ保存	○
Case 6	(1) アンチウイルスソフトウェアの状態を確認	○
	(2) ファイルを検索して Excel ファイルを開く	○
	(3) Bandicam の画面を開いた後，録画を停止	×
	(1) Outlook を起動してメールを閲覧	○
	(2) Outlook の予定表を改変	△
	(3) 連絡先を閲覧	○
Case 8	(1) メールを閲覧	○
	(2) Webex の起動を試行	○
	(3) Zoom を起動して過去のチャット閲覧を試行	△
	(4) Slack のチャット閲覧を試行	○
	(5) Yarai の状態を確認	○
	(6) Bandicam の状態を確認	×
	(7) mipDlp.exe を確認	○
	(8) Vision One を確認	○
判定内訳		○ 18，△ 3，× 2
活動カバレッジ（○+△）		21/23（91.30%）

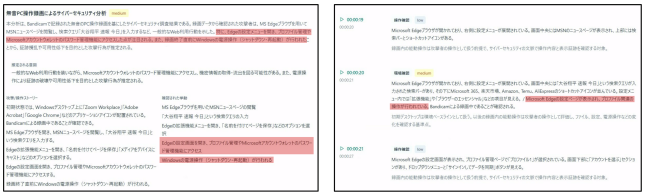


図 2　Case 2 の概要とタイムライン（抜粋）

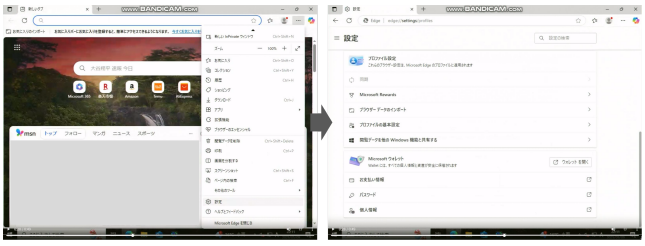


図 3　ブラウザ起動後にウォレットのパスワードを閲覧する様子（一部情報をマスキング）

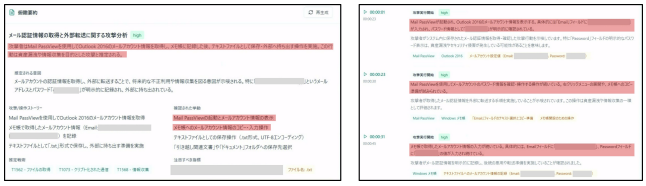


図 4　Case 5 の概要とタイムライン（抜粋，一部マスキング）

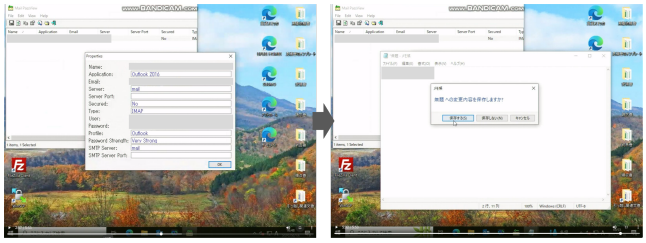


図 5　Mail PassView でアカウント情報を表示し，メモ帳へ保存する様子（一部情報をマスキング）

画面へ移動する流れは図 3 の通りである．

5.3.2　Case 5（○ 3，△ 0，× 0；活動カバレッジ 3/3）

人手による分析結果：（1）Outlook でメールを閲覧，（2）Mail PassView でアカウント情報を取得，（3）メモ帳に保存．

図 4 に，本システムによって出力された Case 5 の概要とタイムラインを一部抜粋して示す．生成結果は，Outlook のメール閲覧，Mail PassView によるメールアカウント情報の表示，および表示された情報のメモ帳への記録・保存に言及しており，3 件すべてを完全対応と判定した．

実際に動画で記録され，キーフレームとして抽出された，Mail PassView でアカウント情報を表示した後，メモ帳へ記録・保存する流れは**図 5** の通りである．

5.3.3　Case 6（○ 2，△ 0，× 1；活動カバレッジ 2/3）

人手による分析結果：（1）アンチウイルスソフトウェアの状態を確認，（2）ファイルを検索して Excel ファイルを開く，（3）Bandicam の画面を開いた後に録画を停止．

図 6 に，Case 6 の概要とタイムラインのうち Bandicam に関する部分を抜粋して示す．生成結果は Bandicam の設定画面を確認したことには言及したが，録画を停止したことへの記述は確認できなかった．このため，最初の 2 件を完全対応，録画停止を非対応と判定した．

録画停止直前に抽出されたキーフレームは**図 7** の通りである．画面上ではマウスカーソルが停止アイコン上に位置

© 2026 Information Processing Society of Japan

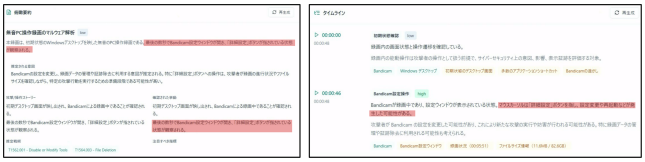


図 6　Case 6 の概要とタイムライン（抜粋）

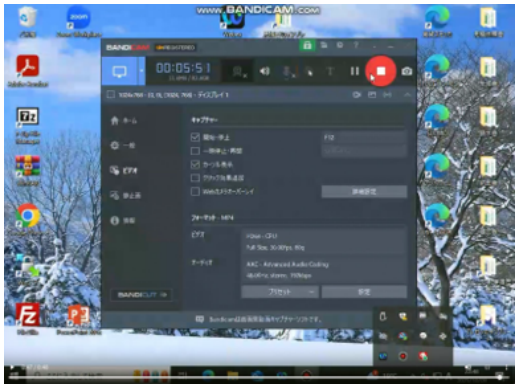


図 7　Bandicam の録画停止直前の画面

しており，この直後攻撃者の手によって録画が終了された．

5.4　考察とまとめ

ブラウザや Outlook の起動，メールやパスワードの閲覧，ファイルの探索，アカウント情報の取得と保存，セキュリティソフトウェアの状態確認等，画面上に比較的明確な変化として現れる操作については，おおむねタイムライン上に反映された．また，複数のアプリケーションを順次操作したケースにおいても，各操作が時系列に沿って出力されており，VLM によるフレーム単位の記述と LLM による時系列統合を組み合わせることで，攻撃活動の主要な流れを再構成できる可能性が示された．

一方，ブラウザの起動や Outlook の予定表に対する操作等では，対象となるアプリケーションや画面の状態は認識できたものの，実際に行われた操作を十分な具体性で記述できず，部分一致となった．特に Outlook の予定表に「aaaa...」のような文字列を嫌がらせ的に登録された操作について，登録の事実自体は認識しているものの，それが嫌がらせ的なものであることは認識できておらず，予定の登録というそれ自体は一般的な動作に対して，悪意や攻撃性を伴うものかどうか判定する部分に課題が見られた．また，画面録画ソフトウェア Bandicam を認識した後に録画を停止した操作等は，生成されたタイムラインと一致しなかった．これは，操作の完了後に即時録画が停止してしまうため事後情報が画面上に明確な結果として残らず判定が難しいこと，また停止操作時に押下したボタンが「録画を停止する」のように一意に停止することが判定できるものでなく，「■」のアイコンのみでその意味理解に推量の介在する余地があったこと，等が複合した結果であると推察される．このことから，攻撃者の意図や操作に続く結果を推定する必要がある活動に対する認識のためには，別途作りこみが必要であることが示唆された．

6.　おわりに

本研究では，RAT を介した攻撃者操作を画面録画として収集・整理するとともに，動画から操作内容のタイムラインと概要を生成する分析システムを試作した．8 件の侵入セッションに含まれる 23 件の活動を対象とした予備評価では，部分対応を含む活動カバレッジが 91.30%であることを示した．以上より，本手法が RAT 操作録画に含まれる主要な活動を時系列に整理し，分析者による侵入後活動の把握を支援できる可能性を示した．

謝辞　本研究の一部は，NICT（国立研究開発法人情報通信研究機構）の事業「2025 年度サイバー攻撃に関する解析作業」によるものである．本研究を進めるにあたって有益な助言と協力を頂いた関係各位に深く感謝申し上げる．

参考文献

[1] Egele, M. et al.: A Survey on Automated Dynamic Malware-Analysis Techniques and Tools, *ACM Computing Surveys*, Vol. 44, No. 2, pp. 1–42 (2012).
[2] Farinholt, B. et al.: To Catch a Ratter: Monitoring the Behavior of Amateur DarkComet RAT Operators in the Wild, *IEEE S&P*, pp. 770–787 (2017).
[3] Bilodeau, O. and Bergeron, A.: I Watched You Roll the Die: Unparalleled RDP Monitoring Reveal Attackers Tradecraft, *Black Hat USA* (2023).
[4] Baechler, G. et al.: ScreenAI: A Vision-Language Model for UI and Infographics Understanding, *IJCAI*, pp. 3058–3068 (2024).
[5] Ma, Z. et al.: DrVideo: Document Retrieval Based Long Video Understanding, *CVPR*, pp. 18936–18946 (2025).
[6] Jin, Y. et al.: ScreenLLM: Stateful Screen Schema for Efficient Action Understanding and Prediction, *WWW*, pp. 2008–2013 (2025).
[7] Huntress: 2025 Cyber Threat Report, Technical report (2025). `https://www.huntress.com/resources/2025-cyber-threat-report`.
[8] Yang, R. et al.: RATScope: Recording and Reconstructing Missing RAT Semantic Behaviors for Forensic Analysis on Windows, *IEEE TDSC*, Vol. 19, No. 3, pp. 1621–1638 (2022).
[9] Ding, H. et al.: AIRTAG: Towards Automated Attack Investigation by Unsupervised Learning with Log Texts, *USENIX Security*, pp. 373–390 (2023).
[10] Hanawa, G. et al.: Investigation of Screen Information in Dynamic Malware Analysis and Consideration of Its Applications, *Journal of Information Processing*, Vol. 33, pp. 619–630 (2025).
[11] Tsuda, Y. et al.: サイバー攻撃誘引基盤 STARDUST, *CSS*, pp. 472–479 (2017).
[12] Dittrich, D. et al.: The Menlo Report: Ethical Principles Guiding Information and Communication Technology Research, Technical report, U.S. DHS (2012).
[13] Rossow, C. et al.: Prudent Practices for Designing Malware Experiments: Status Quo and Outlook, *IEEE S&P*, pp. 65–79 (2012).

© 2026 Information Processing Society of Japan

研究倫理

本研究は，RAT を介して実環境から接続した操作者の遠隔操作を観測・記録するものであり，人の行動に由来するデータを扱うこと，および実マルウェアを動作させることから，操作者のプライバシーと第三者への影響に関する倫理的配慮を要する．本研究分野を対象とする Institutional Review Board（IRB）に相当する制度は我々の組織には存在しないため，Menlo Report [12] に加えて，マルウェア実験 [13] や同種の RAT 観測 [2] をはじめとした各種先行研究を参照し，研究によって生じ得る利益とリスクを検討した上で本研究を設計した．

第一に，観測対象となる RAT 操作者のプライバシーに配慮した．本研究では，攻撃者による探索や情報取得を観測するために実組織を模擬した環境を構成する一方，環境内に配置するメール，認証情報，個人情報等は模擬データとし，有効な認証情報，実在する個人に関する情報，および第三者に影響を与える機密情報は使用しなかった．また，本研究の目的は個々の操作者を特定または追跡することではなく，RAT を介した侵入後の画面上の操作過程を観測・分析することにある．操作者には観測について事前に通知していないが，これは観測環境であることの通知自体が操作者の行動を変化させ，本研究が対象とする侵入後行動の観測を困難にするためである．その代わり，収集・分析する情報を研究目的に必要な範囲に限定し，操作者の IP アドレス等の個々の操作者の識別につながり得る情報は本稿では報告しない．また，掲載する画面についても必要に応じて情報をマスキングした．

第二に，実マルウェアの実行および観測に伴う第三者への影響を抑制した．実験は，STARDUST 上の並行ネットワーク内で実施した．実験中のネットワーク通信は監視され，外部への不適切な通信等が認められた場合には必要に応じて遮断可能な運用体制の下で RAT を実行した．また，RAT 検体は事前に準備したスナップショット上で実行し，各実験の終了後には環境を初期状態へ復元した．これらにより，RAT の実行および遠隔操作に伴う影響が研究環境外の第三者や実運用環境へ及ぶリスクの低減を図った．

第三に，収集したデータの取扱いにも配慮した．画面録画には，攻撃者が入力した文字列，アクセスしたファイルやサービス，マルウェアの実行状況等の取扱いに注意を要する情報が含まれ得る．このため，Study 2 で用いる動画，キーフレーム，OCR 結果，および生成された分析結果は，外部のクラウド型生成 AI サービスへ送信せず，VLM および LLM を含めてローカル環境内で処理した．

以上の対策により，RAT 操作者および第三者に生じ得るプライバシー上・セキュリティ上のリスクを可能な範囲で低減した．一方，本研究によって RAT 侵入後の実際の操作過程を把握し，検知方法や防御対策の検討に資する知見を得られるという研究上・公益上の利益が期待される．これらの利益と残存するリスクを比較し，上記のリスク軽減策の下で本研究を実施・報告することは妥当であると判断した．

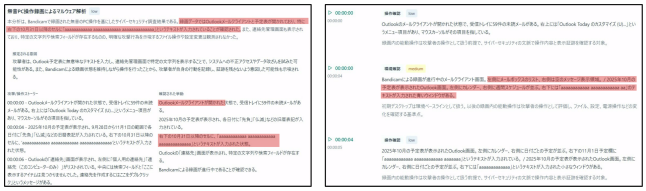


図 A·1　Case 7 の概要とタイムライン（抜粋）

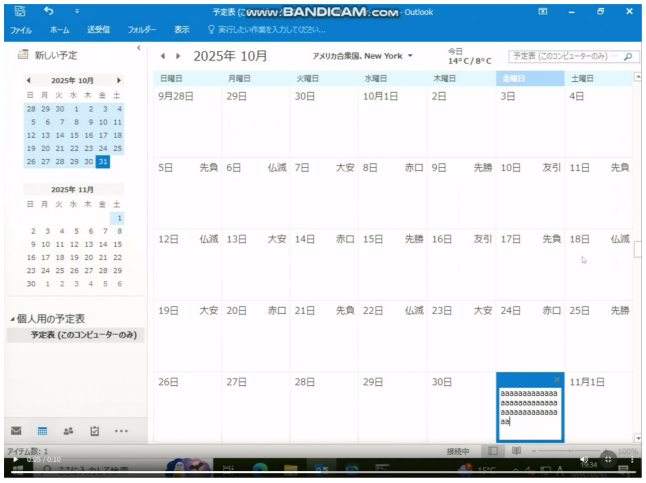


図 A·2　Outlook の予定表に「aaaa. . .」を入力する様子

付　　録

A.1　補足ケーススタディ

A.1.1　Case 7（○ 2，△ 1，× 0；活動カバレッジ 3/3）

人手による分析結果：（1）Outlook を起動してメールを閲覧，（2）Outlook の予定表を改変，（3）連絡先を閲覧．

図 A·1 に，本システムによって出力された Case 7 の概要とタイムラインを一部抜粋して示す．メール閲覧と連絡先閲覧は完全対応となった．予定表について，生成結果は「aaaaa. . .」という長い文字列が入力されたことに言及したが，予定表項目の改変としての記述が十分に具体的ではなかったため部分対応と判定した．評価では，この入力が嫌がらせ目的であったかという意図は判定条件に含めていない．実際の画面を図 A·2 に示す．

A.1.2　Case 8（○ 6，△ 1，× 1；活動カバレッジ 7/8）

人手による分析結果：（1）メールを閲覧，（2）Webex の起動を試行，（3）Zoom を起動して過去のチャット閲覧を試行，（4）Slack のチャット閲覧を試行，（5）Yarai の状態を確認，（6）Bandicam の状態を確認，（7）mipDlp.exe を確認，（8）Vision One を確認．

図 A·3 に，本システムによって出力された Case 8 の概

© 2026 Information Processing Society of Japan

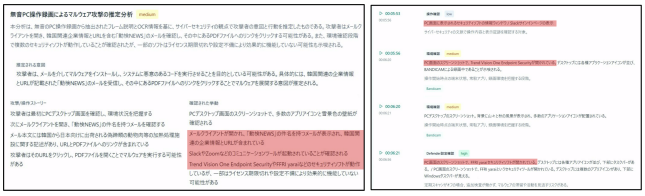


図 A·3 Case 8 の概要とタイムライン（抜粋）

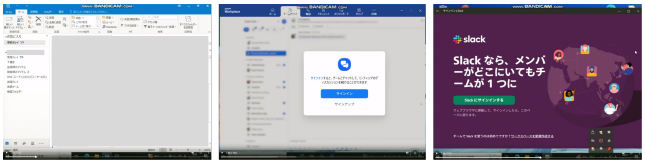


図 A·4 複数のアプリケーションを起動して各種情報を閲覧する様子（一部情報をマスキング）

要とタイムラインを一部抜粋して示す．8 件中 6 件は完全対応となった．Zoom については起動への言及はあったが過去チャットの閲覧対象までは明示されなかったため部分対応，Bandicam については対応する記述がなかったため非対応と判定した．複数のアプリケーションを順次開いて情報を閲覧する画面を**図 A·4** に示す．

A.2 各種プロンプトとパラメータ

前述の通りフレーム説明の VLM には `qwen3-vl:30b`，タイムラインと俯瞰要約生成の LLM には `gpt-oss:20b` を，`Ollama 0.30.0` 上でデフォルトパラメータの設定で利用した．具体的には，`qwen3-vl:30b` については，`temperature` が `1.0`，`top_k` が `20`，`top_p` が `0.95`，`gpt-oss:20b` については `temperature` が `1.0`，`top_k` が `40`，`top_p` が `0.9` であった．

また，以下に分析システムの実装・評価に用いたフレーム説明，タイムライン作成，および要約生成のプロンプトを示す．なお，LLM/VLM 間のデータのやり取りには JSON 形式を用いており，各プロンプトに JSON で出力することやその仕様を記載していたが，ここでは紙面の都合上割愛する．

フレーム説明生成プロンプト

You are analyzing a PC operation recording in a cybersecurity/malware-analysis context. Analysis context: Bandicam is recording software used to capture this video, so its mere presence, tray icon, overlay, or recording UI is not attacker behavior. Only treat Bandicam as security-relevant if the visible user explicitly opens, changes, disables, or manipulates it. Software or shortcuts already visible on the initial desktop are part of the prepared analysis environment; do not infer attacker intent from their presence alone. Examples such as 7-Zip or WinRAR on the initial desktop do not by themselves indicate compression, staging, or exfiltration. Treat such tools as attack-relevant only when the visible user explicitly operates them, or when new tools/files not present in the initial state appear later and may have been installed, downloaded, or created. All active operations recorded in the video should be treated as attacker actions, not analyst actions. All natural-language values, explanations, events, phases, security relevance text, observations, and list items must be written in Japanese.

タイムライン作成プロンプト

You are a senior cybersecurity analyst. Create a Japanese timeline JSON for a PC-operation video. Use only the supplied frame observations. Prefer malware-analysis phases such as preparation, file inspection, execution, behavior observation, network confirmation, alert/result review, and reporting when supported.

要約生成プロンプト

You are a senior analyst specializing in malware analysis and incident response. Refer to the frame descriptions extracted from the PC operation recording, the OCR data, and the timeline, and provide a comprehensive summary in Japanese that explains, within the context of cybersecurity, what kind of attacks or operations the malware or attacker likely carried out and with what intent. Maintain the specified format for JSON keys, and write all descriptions, array elements, titles, summaries, observations, tactic names, and notes in Japanese. For points that cannot be definitively determined, clearly state “possible” or “suggested.” Do not fabricate IOCs or attack names that are not present in the screen evidence.

© 2026 Information Processing Society of Japan